

# Dev Legacy — Compte-rendu de mission

## Maintenance & modernisation — Unify

|                      |                                                                                                             |
|----------------------|-------------------------------------------------------------------------------------------------------------|
| Projet               | Unify — plateforme sociale de running (React Native / Expo + microservice NestJS)                           |
| Équipe               | Tim Hrdy — Chantiers 1 & 2, rapport · Guillaume Lafay — Chantier 3                                          |
| Dépôt                | <a href="https://github.com/guiguil03/Unify-App">https://github.com/guiguil03/Unify-App</a>                 |
| Branche              | features/post-profil                                                                                        |
| Pull Request         | <a href="https://github.com/guiguil03/Unify-App/pull/10">https://github.com/guiguil03/Unify-App/pull/10</a> |
| Dates d'intervention | 5-6 juin et 12 juin 2026                                                                                    |

## 1. Reprise en main

**État du projet au retour.** Monorepo à deux têtes : l'app mobile Expo SDK 55 / React Native 0.83 à la racine, et un microservice NestJS 10 ( `micro-affil/` ) en Clean Architecture. Le backend de données est Supabase.

**Temps pour le faire tourner :** ~15 min pour l'app ( `npm install + expo start` , rien de cassé côté lancement) ; le microservice **ne compilait pas** (voir Chantier 2).

- Frictions rencontrées à la reprise :**
- **Build du microservice cassé :** `npm run build` échoue ( `error TS5095` ) — c'est devenu notre Chantier 2.
  - **Lint du microservice cassé :** 21 erreurs de parsing (ESLint tentait d'analyser les `.d.ts` générés dans `dist/` ).
  - **Dépendance morte :** `firebase` déclaré dans `package.json` mais **importé nulle part** (l'app utilise exclusivement Supabase) — et c'est lui qui portait la faille **critique** `protobufjs` .
  - **Dépendances parasites :** deux librairies React Native ( `@react-navigation/bottom-tabs` , `@react-native-community/datetimepicker` ) déclarées... dans le backend NestJS, sans aucune référence dans `src/` .
  - **Artefact de build versionné :** un dossier `Unify.app/` (binaire iOS compilé, ~70 fichiers) committé dans le dépôt par erreur.
  - `.env` requis pour lancer le microservice (variables Supabase) — non versionné, à recréer.

 Capture à insérer : le projet qui démarre (terminal `expo start` + simulateur affichant l'écran d'accueil)

## 2. Tableau de bord « avant »

Mesures prises **avant toute intervention** (5 juin 2026) :

| Indicateur                                          | App mobile (racine)                                                         | Microservice <code>micro-affil</code>                                                 |
|-----------------------------------------------------|-----------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| Vulnérabilités ( <code>npm audit</code> )           | <b>24</b> (1 critique, 6 élevées, 17 modérées)                              | <b>36</b> (1 critique, 17 élevées, 14 modérées, 4 faibles)                            |
| Dépendances obsolètes ( <code>npm outdated</code> ) | <b>40+</b> paquets en retard (dont React Navigation v6 → v7, ESLint 8 → 10) | NestJS <b>10</b> (latest : 11), <code>@typescript-eslint</code> <b>6</b> (latest : 8) |
| Build / lint OK ?                                   | Tests OK · lint non bloquant                                                | <b>Build KO</b> (TS5095) · <b>Lint KO</b> (21 erreurs)                                |
| Nb de tests / couverture                            | 14 tests, 4 suites (filet existant)                                         | 7 tests, 2 suites · couverture 100 % des unités testées                               |
| Temps de réponse clé (back)                         | —                                                                           | <i>non mesuré (env Supabase requis)</i>                                               |

Sortie `npm audit` initiale (extraits réels) :

```
# App mobile (racine)
24 vulnerabilities (17 moderate, 6 high, 1 critical)

protobufjs <=7.5.7 [CRITIQUE]
  * Arbitrary code execution in protobufjs
  * Prototype injection in generated message constructors
  via: firebase → @firebase/firestore → @grpc/proto-loader → protobufjs

lodash <=4.17.23 [ÉLEVÉE]
  * Code Injection via `_.template`
  * Prototype Pollution via `_.unset` / `_.omit`

# Microservice micro-affil
36 vulnerabilities (4 low, 14 moderate, 17 high, 1 critical)
  multer / express / body-parser / qs [ÉLEVÉES] — pile HTTP NestJS 10
```

 Capture à insérer : sortie complète de `npm audit` et `npm outdated` avant intervention (terminal)

### 3. Fiche de cadrage

| Chantier                | Détail                                                                                                                                                                                                                                                                                                                                                                       | « Fait » = quand...                                                                          |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| <b>C1 — Mise à jour</b> | <b>NestJS 10 → 11</b> (majeure, breaking changes Express 5); suppression <code>firebase</code> (dépendance morte portant la faille critique); <code>lodash</code> 4.17.23 → 4.18.1; <code>@typescript-eslint</code> 6 → 8; correctifs <code>lockfile</code> ( <code>node-forge</code> , <code>xmldom</code> , <code>shell-quote</code> ...). <b>Plan de rollback : §C1.4</b> | <code>npm audit</code> = 0 critique / 0 élevée sur les deux projets ; build + 14 tests verts |
| <b>C2 — Correctif</b>   | Build du microservice cassé : <code>npm run build</code> → <code>error TS5095</code> . Fichiers : <code>micro-affil/tsconfig.json</code> , <code>micro-affil/.eslintrc.js</code>                                                                                                                                                                                             | <code>tsc</code> exit 0 ; lint 0 erreur ; tests verts                                        |
| <b>C3 — Évolutif</b>    | Guillaume Lafay — deep linking d'authentification + inscription via Edge Function Supabase. Fichiers : <code>App.tsx</code> , <code>AuthService</code> , <code>AuthContext</code>                                                                                                                                                                                            | Flux d'auth Google fonctionnel via deep link, testé sur device                               |

**Répartition :** Tim Hrdy → C1 + C2 + rapport · Guillaume Lafay → C3.

Avant toute montée de version : exécution de la suite existante pour **figer le comportement de référence** — `npm test` : **14 tests / 4 suites, tous verts**. Ce même filet est rejoué après chaque étape.

| Requet | Avant | Après | Nature |
|--------|-------|-------|--------|
|--------|-------|-------|--------|

| Paquet                                                                                 | Avant       | Après                 | Nature                                                         |
|----------------------------------------------------------------------------------------|-------------|-----------------------|----------------------------------------------------------------|
| @nestjs/common · core · platform-express                                               | ^10.0.0     | ^11.1.24              | 🚨 <b>Majeure</b> (breaking changes)                            |
| firebase (+ sous-arbre protobufjs / grpc )                                             | ^11.6.1     | <b>supprimé</b>       | Dépendance morte — élimine la faille <b>critique</b>           |
| lodash                                                                                 | 4.17.23     | 4.18.1                | Faible élevée (Code Injection / Prototype Pollution)           |
| @nestjs/cli / @nestjs/schematics                                                       | ^10 / —     | ^11.0.21 / ^11.1.0    | Outillage                                                      |
| @typescript-eslint/*                                                                   | ^6.0.0      | ^8.60.1               | Outillage (corrige glob , minimatch , tmp ...)                 |
| @react-navigation/bottom-tabs , @rn-community/datetimetypepicker ( dans le backend ! ) | présentes   | <b>supprimées</b>     | Parasites — réduction de surface d'attaque                     |
| shell-quote (transitif, via react-devtools-core )                                      | 1.8.3       | 1.8.4                 | Faible <b>critique</b> publiée le 12/06, corrigée le jour même |
| node-forge , @xmldom/xmldom , flatted , minimatch , picomatch ... (transitifs)         | vulnérables | corrigés via lockfile | Faibles élevées                                                |

```
$ grep -rn -i "firebase|firestore" . --exclude-dir=node_modules --exclude=package-lock.json
package.json:43:      "firebase": "^11.6.1",           ← seule occurrence côté JS
android/.../AndroidManifest.xml: com.google.firebase.messaging.* ← FCM natif
                                   (push expo-notifications, indépendant du paquet npm)
```

Guide de migration officiel NestJS 11 ([docs.nestjs.com/migration-guide](https://docs.nestjs.com/migration-guide)) — points relevés et impact sur notre code :

| Breaking change (changelog NestJS 11)                                                                                                                                                                                        | Impact sur <code>micro-affil</code>                                                                                           |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| <b>Node.js ≥ 20 requis</b> (16/18 abandonnés)                                                                                                                                                                                | ✅ OK — Node 22.13.1 en local et en CI                                                                                         |
| <b>Express 4 → 5</b> dans <code>@nestjs/platform-express</code> ( <code>path-to-regexp v8</code> : les routes wildcard <code>*</code> doivent être nommées <code>*splat</code> , syntaxe des paramètres optionnels modifiée) | ✅ Aucun impact — nos contrôleurs n'utilisent que des routes littérales ( <code>@Post()</code> , <code>@Get('/:code')</code> ) |
| Parsing des query strings (Express 5, mode <code>simple</code> par défaut)                                                                                                                                                   | ✅ Aucun impact — DTO validés par <code>class-validator</code> , pas de query imbriquée                                        |
| <code>cache-manager v6</code> si utilisé                                                                                                                                                                                     | ✅ Non utilisé                                                                                                                 |

#### 4.4 Plan de rollback

1. **Branche dédiée** : tout est sur `features/post-profil` — `main` n'est jamais touché ; tant que la PR n'est pas mergée, la prod ne voit rien.
2. **Commits atomiques** → retour arrière ciblé par `git revert <sha>` (upgrade, correctif et hygiène sont des commits distincts).
3. **Lockfiles = source de vérité** : `git checkout <sha-avant> -- package-lock.json && npm ci` restaure l'arbre de dépendances à l'identique en ~1 min.
4. **Builds EAS** : les binaires publiés sont immuables ; en cas de régression mobile, on re-soumet le build précédent (pas de hotfix sauveage).

## 4.5 Preuve de non-régression

```
$ npm run build      (micro-affil)
> tsc
BUILD_EXIT=0 - dist/src/main.js généré

$ npm test           (racine, après toutes les montées)
Test Suites: 4 passed, 4 total
Tests:       14 passed, 14 total

$ npm run test:cov    (micro-affil)
All files        | 100 % stmts | 100 % branch | 100 % funcs | 100 % lines
Tests:          7 passed, 7 total
```

**Gain quantifié** : 60 → 9 vulnérabilités (-85 %), **0 critique / 0 élevée** ; 2 failles critiques d'exécution de code éliminées ; bundle mobile allégé du SDK Firebase complet (inutilisé).

 Capture à insérer : tests au vert + `npm audit` après, dans le terminal

## 5. C2 — Correctif : build du microservice cassé

**Symptôme.** Le microservice ne compile pas :

```
$ cd micro-affil && npm run build
> tsc
tsconfig.json(2,3): error TS5095: Option 'bundler' can only be used when
'module' is set to 'preserve' or to 'es2015' or later.
```

**Reproduction.** Systématique : `npm run build` échoue à chaque exécution, avant toute modification de code. (Le service tournait jusqu'ici en dev via `ts-node-dev --transpile-only`, qui ignore les erreurs de type — c'est pour ça que personne ne l'avait vu.)

**Diagnostic — cause racine.** Le `tsconfig.json` du backend se terminait par :

```
"extends": "expo/tsconfig.base"
```

Un backend NestJS (CommonJS) qui hérite de la config TypeScript d'Expo (front React Native). Cette base impose `moduleResolution: "bundler"` et `customConditions` — incompatibles avec `module: "commonjs"`. Probablement un copier-coller à la création du dossier dans le monorepo. Première correction tentée (`moduleResolution: "node"` seul) → nouvelle erreur TS5098 (`customConditions` hérité lui aussi) : traiter le symptôme ne suffisait pas, il fallait **supprimer l'héritage**, pas le rustiner.

**Correction** (`micro-affil/tsconfig.json`) :

```
"compilerOptions": {
  "module": "commonjs",
+  "moduleResolution": "node",
  ...
},
- "extends": "expo/tsconfig.base"
}
```

Dans la foulée, même famille de problème sur le lint : ESLint analysait les `.d.ts` générés dans `dist/` (21 erreurs de parsing) → exclusion de `dist/` et `coverage/` dans `.eslintrc.js`.

**Test de non-régression.**

```
$ npm run build → exit 0, dist/src/main.js généré
$ npm run lint → 0 erreur (21 → 0)
$ npm test → 14/14 verts
```

La compilation `tsc` (vérification de types complète, vs `--transpile-only` en dev) et le lint font désormais office de **garde-fou permanent** : toute réintroduction du problème casse le build immédiatement.

 Capture à insérer : avant/après dans le terminal (erreur TS5095 → build vert)

## 6. C3 — Évolutif : deep linking d'authentification

**Auteur : Guillaume Lafay** — commit `efaad33` (auteur vérifiable dans l'historique Git : `glafay`).

**Besoin.** Finaliser le flux d'authentification Google : au retour du navigateur OAuth, l'app doit récupérer la session via **deep link** au lieu de laisser l'utilisateur sur un écran mort ; l'inscription doit passer par une **Edge Function** Supabase pour gérer les limites de débit côté serveur.

**Implémentation.** Gestion des deep links dans `App.tsx` (écoute de l'URL de retour OAuth, extraction des tokens, établissement de la session Supabase) ; refactor de `AuthService.register()` vers l'Edge Function ; gestion d'erreurs renforcée dans `AuthContext` (commit `efaad33`, complété par la PR #9 `fix-google-auth`).

**Test.** [Guillaume : compléter le scénario du flux — login Google → retour app via deep link → session active — avec captures]

 Captures à insérer : avant (retour OAuth sans session) / après (deep link → utilisateur connecté)

## 7. Tableau de bord « après » + hygiène Git

| Indicateur                                | App mobile (racine)                               | Microservice <code>micro-affil</code>           |
|-------------------------------------------|---------------------------------------------------|-------------------------------------------------|
| Vulnérabilités ( <code>npm audit</code> ) | <b>9 modérées</b> (0 critique, 0 élevée) — 24 → 9 | <b>0</b> — 36 → 0                               |
| Dépendances obsolètes                     | 41 paquets* (écosystème Expo 55, voir §8)         | 18 (transitifs mineurs)                         |
| Build / lint OK ?                         | Tests OK                                          | <b>Build OK · Lint OK</b> (réparés)             |
| Nb de tests / couverture                  | 14/14 verts (inchangé = non-régression)           | 7/7 verts · couverture 100 % des unités testées |
| Temps de réponse clé (back)               | —                                                 | <i>non mesuré (env Supabase requis)</i>         |

\* Les 9 vulnérabilités modérées restantes sont **toutes** dans l'outillage de build Expo ( `@expo/cli` , `xcode` , `metro-config` ... ), non embarqué dans l'app livrée. Le seul « fix » proposé par npm est un **downgrade Expo 55** → **46** ( `isSemVerMajor` ), refusé car destructeur. Vraie remédiation : **migration Expo SDK 56**, planifiée comme chantier dédié.

```
$ npm audit # racine, après
9 moderate severity vulnerabilities

$ cd micro-affil && npm audit # microservice, après
found 0 vulnerabilities
```

**Hygiène Git** — branche dédiée `features/post-profil` , commits atomiques (1 commit = 1 intention) :

```
* b74f6f7 chore(micro-affil): exclude dist/ et coverage/ du lint
* f96ce87 security: fix critique shell-quote (GHSA-w7jw-789q-3m8p) via npm audit fix
* 430203b security: audit et correction des vulnérabilités des dépendances
* d9944a8 Merge pull request #9 from guiguil03/fix-google-auth
| * fc8ec92 fix auth
* | efaad33 Add deep link handling for authentication in App component; ...
```

Captures à insérer : `npm audit` après (les deux projets) + page de la PR GitHub avec l'historique des commits

## 8. Bilan & rétro legacy

**Ce que les vieilles deps / le vieux code ont coûté :**

- La faille **critique** (exécution de code arbitraire via `protobufjs` ) venait d'un SDK **que personne n'utilisait**. Firebase a été ajouté un jour, jamais branché, jamais retiré : chaque dépendance « au cas où » est une dette de sécurité qui court toute seule.
- Le build du microservice était cassé **silencieusement** depuis sa création : le mode dev ( `--transpile-only` ) masquait l'erreur de config. Sans CI qui compile, un projet peut être indéployable sans que personne ne le sache.
- Une **nouvelle faille critique est apparue entre nos deux sessions** ( `shell-quote` , advisory du 12/06 ) : la sécurité des dépendances n'est pas un état, c'est un flux. Un audit ponctuel périmé en jours.

**Ce qu'on change dans nos habitudes :**

- `npm audit --audit-level=high` **bloquant en CI** + compilation `tsc` du microservice à chaque PR (plus jamais de build cassé silencieux).
- Dependabot/Renovate** sur le dépôt : les correctifs de sécurité arrivent en PR automatiques, petits et fréquents, au lieu d'un rattrapage massif et risqué.
- Une **dépendance ajoutée = une dépendance justifiée** ; revue trimestrielle de `npm outdated` pour ne plus accumuler 40 paquets de retard.
- Ne pas mélanger les intentions dans un commit** : notre premier commit (430203b) regroupait l'upgrade C1 et le correctif C2 — les deux suivants sont redevenus atomiques. Leçon intégrée en cours de mission.
- Sortir les artefacts de build ( `Unify.app/` , `dist/` ) du dépôt et du lint : `.gitignore` à compléter.

**Prochaine échéance identifiée** : migration **Expo SDK 56** (efface les 9 vulnérabilités résiduelles) — à mener avec la même méthode : filet, changelog, branche dédiée, rollback.

## Annexe A — Journal de bord

| Horodatage      | Événement                                                                                                                                                                                                                                                 |
|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 05/06<br>~23h15 | Reprise du projet. <code>npm audit</code> : 24 vulnérabilités app (1 critique) / 36 micro (1 critique). <code>npm outdated</code> : 40+ paquets en retard.                                                                                                |
| 05/06<br>~23h30 | Filet posé : <code>npm test</code> → 14/14 verts (comportement de référence figé).                                                                                                                                                                        |
| 05/06<br>~23h40 | <code>npm audit fix --dry-run</code> sur les deux projets pour trier correctifs sûrs / cassants. <b>Décision : refuser <code>--force</code></b> (proposait un downgrade Expo 55 → 46).                                                                    |
| 05/06<br>~23h50 | <code>npm audit fix</code> racine : 24 → 10. Critique <code>protobufjs</code> et toutes les élevées corrigées via lockfile.                                                                                                                               |
| 06/06<br>~00h05 | micro-affil : lecture du guide de migration NestJS 11 (Node ≥ 20 ✓, Express 5, routes wildcard nommées — non concernés).<br>Suppression des 2 deps RN parasites. Montée NestJS 10 → 11 + <code>@typescript-eslint</code> 8.                               |
| 06/06<br>~00h15 | <b>Impasse n°1</b> : <code>npm run build</code> → <code>error TS5095</code> . Première piste ( <code>moduleResolution: "node"</code> ) → nouvelle erreur <code>TS5098</code> .                                                                            |
| 06/06<br>~00h25 | <b>Cause racine trouvée</b> : <code>extends: "expo/tsconfig.base"</code> dans le <code>tsconfig</code> du backend. Suppression de l'héritage → build vert. Le service ne compilait en fait <b>jamais</b> ( <code>--transpile-only</code> masquait tout).  |
| 06/06<br>~00h35 | Dernier <code>npm audit fix</code> micro ( <code>glob</code> ) → <b>0 vulnérabilité</b> . Re-build + re-test : verts.                                                                                                                                     |
| 06/06<br>~00h45 | Question d'équipe : « on n'utilise pas Firebase, si ? » → vérif par grep : <b>aucun import</b> . Suppression de <code>firebase</code> → sous-arbre <code>protobufjs</code> / <code>grpc</code> éliminé à la racine. Tests verts.                          |
| 06/06 00h59     | Commit <code>430203b</code> (audit + correctifs) — <i>rétrospectivement trop gros : mélange C1/C2, voir rétro</i> . Push.                                                                                                                                 |
| 12/06<br>~02h00 | Relecture de l'énoncé exact. Re-audit de contrôle : <b>nouvelle faille critique apparue entre-temps</b> ( <code>shell-quote</code> , GHSA-w7jw-789q-3m8p, advisory publié après notre session).                                                           |
| 12/06 02h17     | Fix <code>shell-quote</code> 1.8.3 → 1.8.4 ( <code>npm audit fix</code> , non-cassant), tests verts. Commit atomique <code>f96ce87</code> .                                                                                                               |
| 12/06<br>~02h25 | Lint micro-affil : 21 erreurs de parsing ( <code>dist/</code> analysé par ESLint). Exclusion <code>dist/</code> + <code>coverage/</code> → 0 erreur. Commit atomique <code>b74f6f7</code> . <code>npm run test:cov</code> : 100 % sur les unités testées. |
| 12/06<br>~02h40 | Refonte du compte-rendu selon le canevas du sujet.                                                                                                                                                                                                        |

## Annexe B — Référence

Rapport d'audit détaillé (CVE par CVE, CVSS, CWE) : `docs/AUDIT-SECURITE.md` dans le dépôt.